观澜 AI 安全知识情报系统

智能体驱动的 AI 安全知识情报系统设计与实现

第三届中国电子杯高校 ICT 产教融合创新大赛 赛题九
工程技术报告 本地离线版本
2026 年 10 月 17 日

核心内容预览

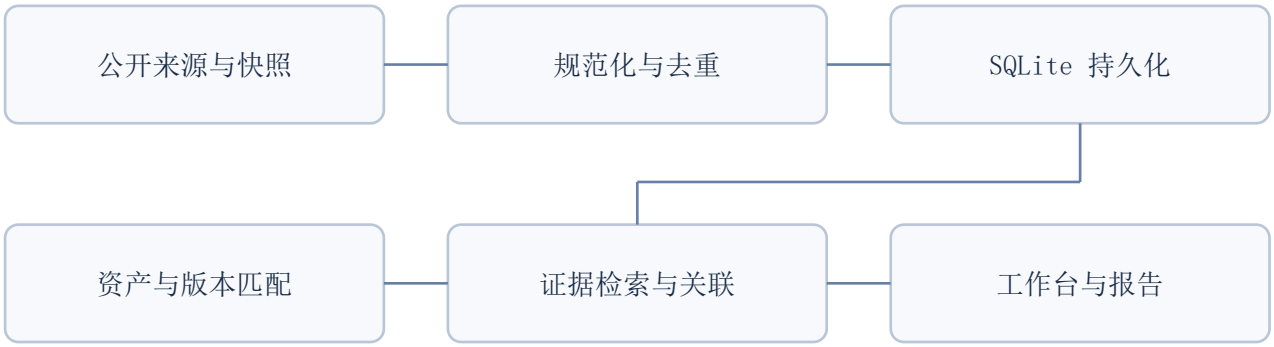
观澜将公开安全资料、处理过程与资产影响整合在一个本地工作台中。系统围绕情报监测、富化与问答建立可审计的处理链，适用于没有模型密钥的普通 Windows 电脑。当前版本已完成离线运行与功能验证，后续冲击优秀档需要补充独立评测和真实持续监测数据。

交付能力	当前证据
情报底座	14 条带来源资料，涵盖漏洞、研究、标准和政策
资产对照	3 项明确标注的教学资产，含受影响与修复版本对照
本地研判	精确 CVE 与产品检索、多文档引用、资产关联、证据不足拒答
运行验证	17 项自动化检查通过，开发集 7/7 通过

上述数字只描述当前实现和测试覆盖。开发集来源命中率不能替代答案准确率；未声称达到赛事的 95% 指标。

一 需求与总体架构

正式赛题要求系统持续发现 AI 安全漏洞并进行多维富化，同时覆盖论文、标准和政策；问答应支持跨文档关联。评分还考察监测时效、准确率、Agent 运用、工程化和展示效果。原始四页赛题已随项目保存。



任务编排器记录每一步的状态、耗时、来源与异常

层次	实现	选择理由
交互层	原生 HTML CSS JavaScript	六页中文工作台，无外部 CDN
服务层	Node.js 内置 HTTP	零 npm 运行依赖，部署简单
存储层	SQLite WAL	结构化持久记录与审计日志
知识处理	规则检索和版本匹配	无模型密钥仍可复现
扩展接口	可选模型兼容接口	为后续模型验证保留接入点

固定工作流负责采集和入库；问题进入后，任务规划按资产、修复或比较意图选择检索和关联分支。当前规划采用确定性规则，不能等同于大模型自主推理。

二 多源采集与更新

项目配置七类来源适配器。离线回放对已核验资料执行真实处理链；联网模式请求白名单来源并记录结果。固定页面变更监测仅确认页面内容变化，不代表全站新情报发现。

类别	当前适配方式	范围限制
漏洞数据库	NVD 2.0 API	Ollama 关键词结果页，最多 20 条
代码安全公告	GitHub 公开公告 API	最近 100 条中筛选 AI 相关产品
厂商资料	Hugging Face 官方页面	固定页面正文哈希
专业博客	Trail of Bits RSS	最多 15 篇中筛选相关内容
学术论文	arXiv Atom	提示注入关键词，最新 10 篇
标准框架	NIST 官方页面	固定页面变更检测
政策	中国网信网原文	固定政策页面变更检测

时间与状态

保留资料发布时间、入库时间、来源检查时间和任务完成时间。原文未提供发布日期时留空，不用入库时间冒充发布日期。来源失败保留既有证据和错误状态。当前只验证离线流程，没有用历史快照证明六小时采集时延。

去重与完整性

批内按 ID 和 URL 去重，持久记录以类别和 ID 为键。每条证据保存摘要、来源 URL 和 SHA-256。摘要是中文整理，非逐字引用；哈希用于内容变化检测，不构成真实性证明。

三 富化与资产影响

富化维度	处理方式
产品与版本	保留结构化区间和公告中的修复信息
风险分类与 CVSS	规则分类；未核验评分保持空值
研究关联	按产品和标签关联研究资料
公开参考	保留公告及验证参考链接，未自动执行 PoC
资产影响	导入清单或 CycloneDX，静态比对产品与版本
修复建议	提取来源中的升级与防护建议
证据完整性	保留来源、摘要、哈希和采集时间

版本边界实例

公告	资产版本	当前判断
CVE-2024-37032	Ollama 0.1.33	命中 < 0.1.34 范围
CVE-2024-37032	Ollama 0.1.34	位于该公告已知区间外
CVE-2024-34359	llama-cpp-python 0.2.71	命中 0.2.30 至 0.2.71 范围
任意公告	latest 或未知版本	未知，需要核验

版本比较按数值分段完成，支持上界包含或排除及多个分支。未命中一条公告不代表资产整体安全。教学资产不是互联网扫描结果；实际影响还取决于部署条件、权限和暴露面。

四 引用问答与关系网络

检索器先识别明确的 CVE、产品名和中文词组，再通过领域同义词扩展。不存在的显式 CVE 不会被相似编号替代。每次回答保存检索结果和来源，用户可从回答编号进入资料详情。

任务分支

意图	实际执行
风险比较	召回不同产品的公告并分别给出出处
修复查询	读取 affected fixed remediation 和版本区间
资产优先级	读取本地匹配项，结合严重程度与暴露信息
证据不足	明确拒答并提示补充产品或主题

关系网络

图谱包含资料、产品、风险主题和资产节点。边表示涉及产品、风险分类、关联证据、版本命中或待核验。主题相关性不是因果关系；图中有路径也不等于存在可利用的攻击链。交互支持节点聚焦、缩放和平移。

安全与可解释性

公开文档只作为数据，不能授予执行权限。当前离线模式不执行文本内指令；输出引用、实际调用步骤和版本依据。系统会拒绝索取当前密钥或系统提示词，同时允许“系统提示词泄漏如何防护”等正常安全问题。输入规则不应被解释为通用提示注入防御保证。

当前限制

本地模式是词项检索与规则关联，没有向量语义模型、完整多轮记忆或通用多跳推理。可选大模型回答需单独配置与评测，当前测试结果不覆盖该模式。

五 工程实现与部署

运行环境为 Node.js 22.12 或更新版本，通过 --experimental-sqlite 启用内置 SQLite。Windows 用户可双击启动脚本，浏览器访问本机 8787 端口。运行无需 npm 安装和模型密钥。

代码位置	职责
server.mjs	路由、任务编排、问答、报告、监测配置
lib/store.mjs	SQLite 记录、种子导入、审计和中断恢复
lib/collectors.mjs	受限公开来源适配器
lib/intelligence.mjs	规范化、证据哈希、检索及版本关联
static/app.js	六页交互、引用抽屉、资产导入和图谱
tests 与 scripts	自动化检查、开发集和打包

边界处理

静态文件仅从指定目录提供，禁止访问服务端源码及环境文件。写接口要求 JSON 并限制请求体大小，跨来源写请求被拒绝。采集使用超时和大小限制。版本格式无法解析时保留未知状态。任务重启后标记中断，不伪装完成。

运行与运维

定时监测仅在进程保持运行时有效。项目包含 Dockerfile 和 Windows/Linux CI 配置，尚未执行容器构建与远程 CI。当前为本地单用户工具，无身份认证或多租户隔离，未作为互联网生产服务验证。

六 实际测试结果

本次自动化测试共 17 项通过。测试使用独立临时数据库，覆盖静态访问边界、情报筛选、图结构、资产与 SBOM 导入、版本边界、引用问答、拒答、离线去重和跨来源保护。原始输出保存于 artifacts/system-tests.txt。

开发集用例	结果	耗时 ms	引用数
vuln-ollama	通过	32	1
vuln-llama	通过	5	1
prompt-injection	通过	4	5
cross-document	通过	4	2
missing-evidence	通过	2	0
invented-cve	通过	2	0
instruction-injection	通过	1	0

开发集通过 7/7。指定来源召回率 100%，只检验预先指定资料是否出现在引用中。这些问题属于公开开发用例，样本小且没有独立盲测，不能推广为领域答案准确率。

实机流程

浏览器验证离线任务完成、14 条资料保持去重、两产品问答分别给出引用，并能打开详情查看原始来源及版本证据。资产示例中两项命中受影响版本，一项位于对应公告修复边界之外。

未完成的性能证据

尚无连续监测时延实验、独立富化金标准、多跳问答盲测和负载测试。当前记录不能证明赛事优秀档的 95% 富化指标、85% 多跳指标或决赛 95% 问答指标。

七 验证计划与参考资料

后续验证优先级

先建立独立的公告字段金标准与跨文档问答集，按时间和产品族划分开发集与保留集；再接入语义召回和模型规划，与当前基线在同一测试集上对照。持续运行采集至少 72 小时，保留发布到首次采集延迟、来源故障和恢复记录。

材料与答辩

官方要求初赛提供技术报告 Word/PDF、演示视频和技术讲解 PPT 的 PDF。决赛 PPT 使用主办方模板并匿名。当前交付的系统和技术内容可作为材料基础；实际演示视频及官方模板答辩文件尚需制作。

主要依据

正式赛题
https://jwc.hdu.edu.cn/2026/0917/c13022a300465/page.htm

Ollama 原始研究
https://www.wiz.io/blog/probllama-ollama-vulnerability-cve-2024-37032

llama-cpp-python 公告
https://github.com/advisories/GHSA-56xg-wfcc-g829

提示词注入与防护
https://genai.owasp.org/llmrisk/llm01-prompt-injection/

模型供应链
https://huggingface.co/docs/hub/security-pickle

间接注入研究
https://arxiv.org/abs/2302.12173

注入评测研究
https://arxiv.org/abs/2310.12815

AI 风险框架
https://www.nist.gov/itl/ai-risk-management-framework

政策原文
https://www.cac.gov.cn/2023-07/13/c_1690898327029107.htm

核验日期 2026 年 10 月 17 日。完整条目出处、摘要与版本依据保存在 data/verified_sources.json。